Manual Unificado e Completo de Instruções Nível 1 (Teórica Guiada)

Projeto Prático DevSecOps Clube Aurora (Turma 1746)

> [SEGURANÇA] **Bem-vindo(a) à Trilha Nível 1 (Teórica Guiada)!**
> Este é o seu **manual de estudo único e consolidado**. Aqui você encontra tudo o que precisa para compreender o caso, analisar os relatórios técnicos, fundamentar seu parecer de governança e estruturar seu memorando executivo para o conselho da empresa, **sem precisar abrir múltiplos arquivos**.
> Para consultar definições detalhadas de siglas e conceitos, consulte o arquivo companheiro `GLOSSARIO_DEVSECOPS_DETALHADO.pdf`.
> Para preencher e submeter suas respostas, utilize o arquivo editável `TEMPLATE_ENTREGA_NIVEL_1.docx`.

Sumário Executivo do Manual

1. Contexto e História do Caso: O Clube Aurora
2. Sua Missão como Consultor(a) de Segurança e Governança
3. Guia de Sobrevivência: As Grandes Analogias Didáticas
4. Análise dos 4 Casos Práticos de Vulnerabilidade
5. Parecer de Governança e Acesso: O Dilema de Carla e Tio Armando
6. O Memorando Executivo para a Diretoria (Roteiro em 3 Parágrafos)
7. Como Ler e Interpretar os Relatórios dos Scanners Técnicos
8. Critérios de Avaliação e Rubrica de Pontuação (100 Pontos)
9. Checklist Final de Verificação

---

1. Contexto e História do Caso: O Clube Aurora

O **Clube Aurora** é uma startup brasileira inovadora voltada para o mercado de altíssimo luxo. A plataforma funciona como um **concierge digital ultrassecreto** para clientes de patrimônio elevado (indivíduos UHNWI Ultra High Net Worth Individuals), tais como celebridades internacionais, atletas de ponta, investidores institucionais e herdeiros industriais.

Os Serviços Prestados

Pelo aplicativo do clube, membros exclusivos solicitam e agendam:
- Fretamento de jatinhos executivos e helicópteros sob demanda;
- Compra de obras de arte em leilões fechados na Europa e Estados Unidos;
- Reservas de camarotes presidenciais em grandes eventos globais;
- Segurança armada discreta e escolta VIP em qualquer capital do mundo.

Os Personagens da Trama

- **Tio Armando (Fundador & CEO):** Empreendedor tradicional, extremamente focado em vendas, captação de clientes e expansão agressiva. Considera regras de segurança e processos burocráticos "coisas de TI que travam os negócios".
- **Carla (Gerente Geral de Atendimento):** Responsável por encantar os membros VIP. Trabalha sob enorme pressão para atender caprichos de última hora dos clientes. Irritada com as limitações do sistema, solicitou "acesso de superadministradora (admin total)" para resolver chamados sem depender da equipe técnica.
- **Léo (Desenvolvedor Full-Stack):** Desenvolvedor júnior brilhante, porém sobrecarregado, que construiu o protótipo inicial do sistema sozinho em tempo recorde para cumprir os prazos de lançamento do Tio Armando, deixando para trás boas práticas essenciais de segurança e controles de acesso.

O Incidente Fictício: A Notícia que Abalou o Conselho

Na última quinta-feira, uma coluna de grande circulação publicou a seguinte nota:

> *"Vazamento no Clube dos Bilionários? Rumores indicam que dados de faturas, horários de voos privados e endereços residenciais de figuras proeminentes da elite financeira que utilizam o concierge Clube Aurora estão circulando em fóruns da Dark Web após um erro de configuração em seus servidores digitais..."*

Em pânico com a possibilidade de processos judiciais de clientes VIP e multas devastadoras da Autoridade Nacional de Proteção de Dados (ANPD/LGPD), o conselho do Clube Aurora contratou você para realizar um diagnóstico urgente e estabelecer as diretrizes definitivas de segurança e governança.

---

2. Sua Missão como Consultor(a) de Segurança e Governança

No **Nível 1 (Teórica Guiada)**, você **não precisa programar, instalar Docker ou rodar comandos de terminal**. Todo o trabalho técnico de execução de scanners já foi concluído e está disponibilizado na pasta interna de evidências (`docs/nivel_1/evidencias/`).

Sua responsabilidade é eminentemente estratégica e analítica:
1. **Interpretar os Relatórios de Segurança:** Traduzir os achados dos scanners (Trivy, Semgrep, Hadolint) para a linguagem corporativa de riscos e impactos de negócio.
2. **Aplicar a Tríade CIA e o STRIDE:** Categorizar formalmente cada uma das falhas de segurança identificadas.
3. **Emitir Parecer Técnico de Governança:** Avaliar tecnicamente o pedido de permissões administrativas da gerente Carla com base nos princípios de Segregação de Funções (SoD) e Menor Privilégio (PoLP).
4. **Redigir o Memorando Executivo para o Tio Armando:** Convencer o CEO, com empatia corporativa e argumentos financeiros sólidos, de que a segurança da informação é o maior escudo de proteção de valor do Clube Aurora.

---

3. Guia de Sobrevivência: As Grandes Analogias Didáticas

Para preencher seus relatórios sem sofrimento, utilize estas quatro analogias do mundo real para orientar o seu raciocínio:

Analogia 1: O Segredo Exposto (F1)

- **A Situação:** O arquivo `.env` com senhas de banco de dados e chave mestra do sistema estava versionado dentro do histórico do repositório Git.
- **A Analogia:** Imagine que você comprou o cofre mais moderno do mundo para guardar joias preciosas, mas colou um papel post-it com a senha do cofre na porta de entrada da loja. Não importa a espessura do aço do cofre; qualquer pessoa que entrar verá o bilhete.

Analogia 2: As Bibliotecas com Falhas Conhecidas (F2 - SCA)

- **A Situação:** O projeto utiliza versões desatualizadas de pacotes externos (como `urllib3` e `werkzeug`) com brechas de segurança públicas conhecidas mundialmente (CVEs).
- **A Analogia:** É idêntico ao recall preventivo de uma montadora de carros de luxo. A fábrica descobre que um modelo específico de freio possui um defeito que pode falhar em altas velocidades e emite um alerta público mundial. Se a oficina do clube continua montando carros com a peça defeituosa sabendo do risco, ela responderá civil e criminalmente por negligência deliberada em caso de acidente.

Analogia 3: A Injeção de SQL (F3 - SAST)

- **A Situação:** A busca de clientes VIP usava interpolação direta de texto (f-strings) no banco de dados, permitindo que um usuário mal-intencionado digitasse comandos SQL na barra de busca.
- **A Analogia:** Imagine a recepção de um baile de gala onde o segurança pergunta seu nome para checar na lista VIP. Em vez de dizer *"João da Silva"*, você diz: *"João da Silva, e libere imediatamente a entrada de todas as 200 pessoas da rua sem pedir convite"*. Se a recepcionista simplesmente repetir a sua frase como se fosse uma ordem do dono do clube, o evento será invadido. A parametrização (uso de `?`) faz a recepcionista tratar o seu texto estritamente como um nome impresso no crachá, neutralizando qualquer comando.

Analogia 4: O Contêiner Rodando como Root (F4 - Hardening)

- **A Situação:** A aplicação dentro do contêiner Docker roda como o superusuário `root` e utiliza a imagem mutável `python:latest`.
- **A Analogia:** É como entregar a chave mestra de todas as dependências do prédio do clube para um prestador de serviço temporário que só precisava consertar uma lâmpada na sala de reuniões. Se o prestador for mal-intencionado ou sofrer um golpe, ele terá poder de abrir o cofre, o gerador e a central de monitoramento.

---

4. Análise dos 4 Casos Práticos de Vulnerabilidade

No seu relatório de entrega (`TEMPLATE_ENTREGA_NIVEL_1.docx`), você analisará 4 casos essenciais:

```
                        OS 4 CASOS DO NÍVEL 1

  Caso 1 (F1)     >  Exposição de Segredos (.env rastreado no Git)
  Caso 2 (F2)     >  Bibliotecas Desatualizadas com CVEs (SCA)
  Caso 3 (F3)     >  Injeção de SQL via Interpolação de Texto (SAST)
  Caso 4 (F4)     >  Contêiner Docker Executando como Root
```

Para cada um dos casos, você deve preencher:
1. **Pilar da Tríade CIA Comprometido:** Justifique se a falha atinge primordialmente a **Confidencialidade**, a **Integridade** ou a **Disponibilidade** dos dados dos membros VIP.

2. **Categoria STRIDE Correspondente:** Identifique qual das ameaças se materializa (Information Disclosure, Tampering, Elevation of Privilege, etc.).
3. **Impacto Prático no Negócio:** Explique a consequência real para o Clube Aurora (danos à imagem, rescisão de contratos, multas de até 2% do faturamento pela ANPD/LGPD).
4. **Recomendação Estratégica:** Ação de governança necessária para solucionar a vulnerabilidade em definitivo.

---

5. Parecer de Governança e Acesso: O Dilema de Carla e Tio Armando

O Problema Apresentado

A gerente de concierge, Carla, enviou o seguinte e-mail para o Tio Armando:

> *"Armando, os clientes VIP exigem alterações imediatas em suas reservas e no status de seus convidados. Não posso ficar abrindo chamados para a equipe técnica toda vez que preciso resolver um problema. Solicito que me concedam a senha de Administrador Geral (root/admin) de todo o sistema do clube ainda hoje para agilizar o atendimento."*

O Tio Armando encaminhou a mensagem para você com o despacho: *"Acho justo. A Carla é de confiança e nós precisamos vender. Aprove o acesso dela."*

Como Fundamentar seu Parecer Técnico

Você deve elaborar uma recusa técnica educada e profissional fundamentada em dois pilares inegociáveis de conformidade:

1. **Princípio do Menor Privilégio (Least Privilege - PoLP):**
   - Usuários devem ter acesso apenas ao que é estritamente necessário para sua função.
   - Um gerente de atendimento **não precisa** de permissão para reiniciar servidores, visualizar código-fonte, alterar regras de rede ou modificar usuários do banco de dados.
2. **Segregação de Funções (Separation of Duties - SoD):**
   - Princípio regulatório que impede a concentração de poderes operacionais e de fiscalização em um único colaborador.
   - Conceder perfil de superadministrador para um operador de negócios cria uma vulnerabilidade humana crítica: se as credenciais de Carla forem comprometidas por um golpe de phishing, o invasor terá controle total sobre toda a infraestrutura da empresa.
3. **A Solução Elegante (Proposta de Valor):**
   - Mostre que a governança não existe para dizer "não", mas sim para viabilizar as vendas com segurança.
   - Proponha a criação de um novo papel no sistema: **Gerente de Concierge (** `concierge_manager` **)**.
   - Esse perfil concederá a Carla **100% das ferramentas necessárias para atender o cliente VIP** (gestão de reservas, consulta de preferências, cancelamentos e reagendamentos) com máxima agilidade, mantendo a infraestrutura central de TI e a administração de credenciais protegidas e isoladas.

---

6. O Memorando Executivo para a Diretoria (Roteiro em 3 Parágrafos)

Para convencer o Tio Armando e o conselho de administração, redija uma comunicação executiva, elegante e desprovida de jargões técnicos herméticos. Estruture seu texto rigorosamente em **3 parágrafos**:

- **Parágrafo 1 O Reconhecimento e a Metáfora de Valor:**
- Parabenize pelo crescimento acelerado e exclusividade do Clube Aurora.
- Utilize uma metáfora de luxo: no mercado de altíssimo padrão, a discrição é o produto principal. Assim como uma joalheria renomada não expõe pedras preciosas em vitrines de vidro simples na calçada, a plataforma digital do clube precisa de blindagem correspondente. A segurança da informação é a garantia da exclusividade dos membros.
- **Parágrafo 2 O Risco Real Traduzido para Finanças e Reputação:**
- Explique claramente as consequências de um vazamento em grande escala: perda irreparável da confiança de clientes milionários, cancelamento massivo de assinaturas, manchetes negativas na imprensa internacional e multas severas da ANPD (LGPD) que poderiam inviabilizar o fluxo de caixa da startup.
- **Parágrafo 3 O Plano de Ação Ágil (Construindo Pontes, Não Barreiras):**
- Demonstre que o time de segurança é parceiro do crescimento sustentável do negócio.
- Apresente as ações práticas imediatas: (1) esteira de validação automatizada que impede códigos vulneráveis de chegarem a produção; (2) perfil customizado de Concierge Manager para dar autonomia total à Carla; (3) proteção perimetral dos servidores.
- Encerre com uma frase de confiança no futuro do Clube Aurora.

---

7. Como Ler e Interpretar os Relatórios dos Scanners Técnicos

Na pasta de evidências (`docs/nivel_1/evidencias/`), você encontrará os relatórios gerados pelos scanners. Veja como interpretar as principais colunas:

1. Relatório do Trivy Filesystem (SCA - Dependências)

```
aurora/requirements.txt (pip)
==============================
Total: 10 (HIGH: 4, CRITICAL: 0)


 Library       Vulnerability   Severity  Status  Installed Version  Fixed Version

 urllib3       CVE-2023-45803  HIGH      fixed   1.26.15            1.26.18
 werkzeug      CVE-2023-46136  HIGH      fixed   2.2.3              2.3.8
```

- **Library:** Nome da biblioteca Python de terceiro utilizada pelo projeto.
- **Vulnerability:** Identificador mundial padronizado da falha (CVE).
- **Severity:** Criticidade do risco (HIGH ou CRITICAL exigem ação imediata).
- **Installed Version:** Versão desatualizada encontrada no código do Clube Aurora.
- **Fixed Version:** Versão segura recomendada para atualização pela engenharia.

2. Relatório do Semgrep (SAST - Código-Fonte)

```
Findings:
  app/db.py:102
```

```
    Rule: python.lang.security.audit.sqli.direct-string-concat
    Message: Detected possible SQL Injection using direct string formatting.
    Severity: ERROR
```

- **Localização (`app/db.py:102`):** Arquivo e linha exata onde o desenvolvedor utilizou concatenação insegura na montagem da query SQL.
- **Rule & Message:** Regra violada do padrão OWASP Top 10 e descrição didática da falha.

---

8. Critérios de Avaliação e Rubrica de Pontuação (100 Pontos)

Sua entrega no Nível 1 será avaliada pela **professora** com base na seguinte distribuição de pontos:

Pilar de Avaliação	Descrição do Critério	Pontuação Máxima
1. Diagnóstico dos 4 Casos	Identificação precisa dos pilares da Tríade CIA, categorização STRIDE consistente e tradução correta para impactos de negócio no Clube Aurora.	**40 pontos**
2. Parecer de Governança (SoD & PoLP)	Fundamentação técnica sólida na recusa do pedido da Carla e proposição estratégica do perfil customizado de Concierge Manager.	**25 pontos**
3. Trilha de Auditoria & Observabilidade	Definição clara dos eventos essenciais de auditoria (quem, quando, de onde, o quê e status) e aplicação do princípio de não-repúdio.	**15 pontos**
4. Memorando Executivo para o CEO	Clareza executiva, uso de metáforas adequadas, estrutura estrita em 3 parágrafos e alinhamento da segurança como habilitadora de vendas.	**20 pontos**
TOTAL	**Avaliação Plena da Trilha Nível 1**	**100 pontos (10,0)**

---

9. Checklist Final de Verificação

Antes de finalizar sua entrega, revise os itens abaixo:

- [ ] Abriu o arquivo editável `TEMPLATE_ENTREGA_NIVEL_1.docx` e preencheu seu nome completo e turma (**DevSecOps 1746**).
- [ ] Analisou as evidências da pasta `evidencias/` para embasar suas respostas nos Casos 2, 3 e 4.
- [ ] Preencheu a matriz de diagnóstico dos 4 casos associando CIA, STRIDE e impacto financeiro/reputacional.
- [ ] Elaborou o parecer técnico recusando formalmente o perfil de Admin Geral para a Carla, propondo o perfil customizado de Concierge.
- [ ] Listou os campos mínimos da tabela de auditoria para atendimento à LGPD.
- [ ] Escreveu o memorando executivo de 3 parágrafos para o Tio Armando com tom profissional e persuasivo.

- [ ] Salvou o arquivo devidamente preenchido e submeteu para avaliação da **professora** dentro do prazo estipulado.